EXPERIMENT 15

Information Gathering and OSINT Reconnaissance Using theHarvester

- **Name:** Shaik Reehan
- **Reg. No.:** 192565071
- **Subject:** Ethical Hacking
- **Course Code:** ITA1413

AIM

To execute and demonstrate passive Open-Source Intelligence (OSINT) gathering on a target domain using **theHarvester** in Kali Linux to enumerate public email addresses, employee names, subdomains, virtual hosts, and IP addresses.

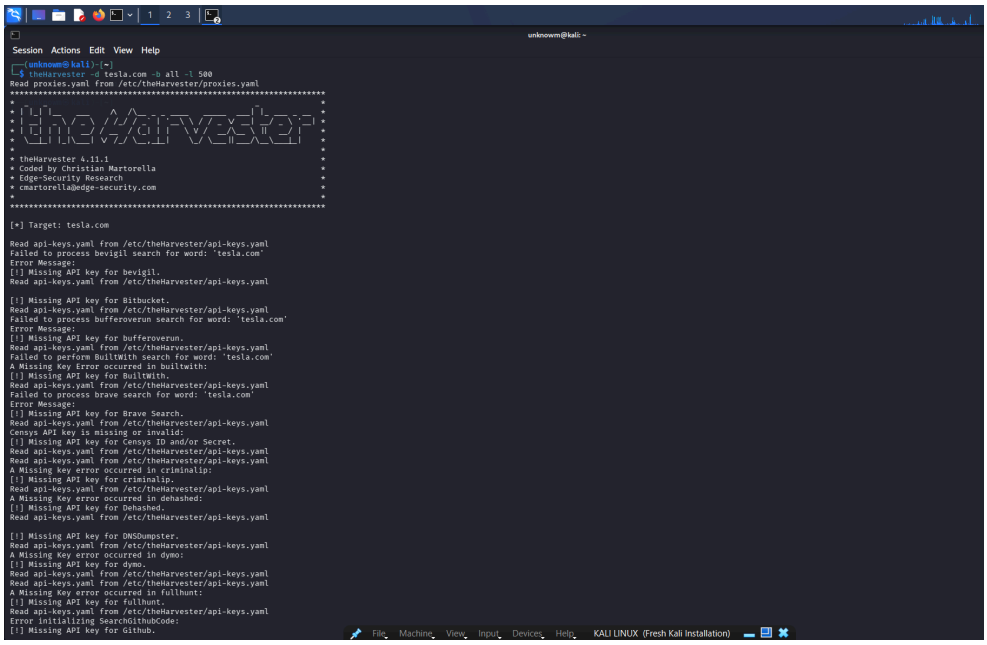
COMMANDS AND DESCRIPTION

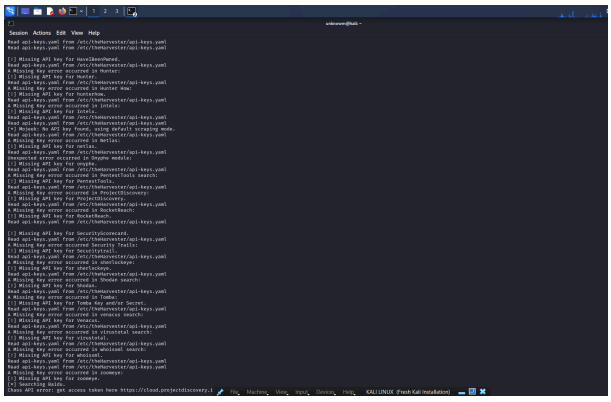
1. **theHarvester Overview:**
    - *Description:* A Python-based reconnaissance tool used during the initial footprinting phase of a penetration test. It passively aggregates publicly available information from major search engines, PGP key servers, Shodan, LinkedIn, and DNS records without interacting directly with the target host.
    - *Syntax:* `theHarvester -d <target_domain> -b <data_source> [options]`
2. **Common Options & Flags:**
    - `-d <domain>`: Specifies the target company domain name (e.g., `tesla.com`, `example.com`).
    - `-b <source>`: Defines the data search engine or source to query (`google`, `bing`, `duckduckgo`, `linkedin`, `crtsh`, or `all`).
    - `-l <limit>`: Restricts the maximum number of search results to analyze (default is 500).
    - `-s`: Utilizes Shodan computer search engine queries to query discovered hostnames.
    - `-f <filename>`: Saves the gathered OSINT findings to both an HTML and XML report file.
3. **Key Execution Command:**
4. Bash

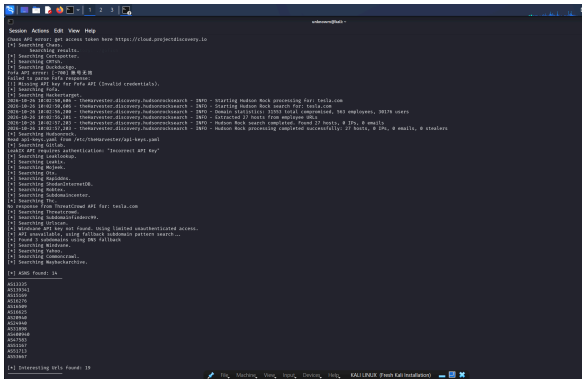
```
None
theHarvester -d tesla.com -l 200 -b duckduckgo,bing,crtsh
```

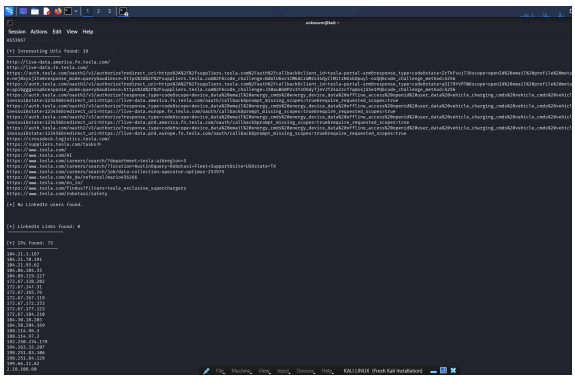
5.

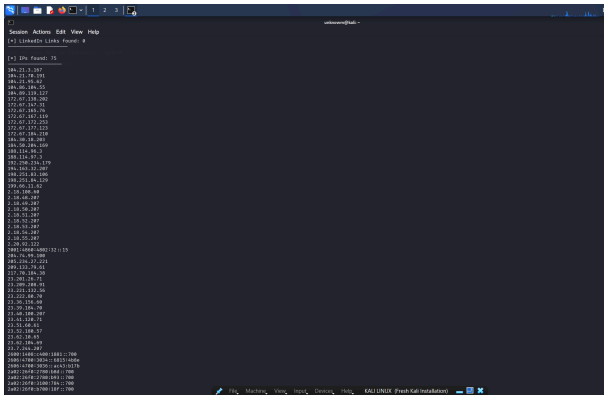
OUTPUT

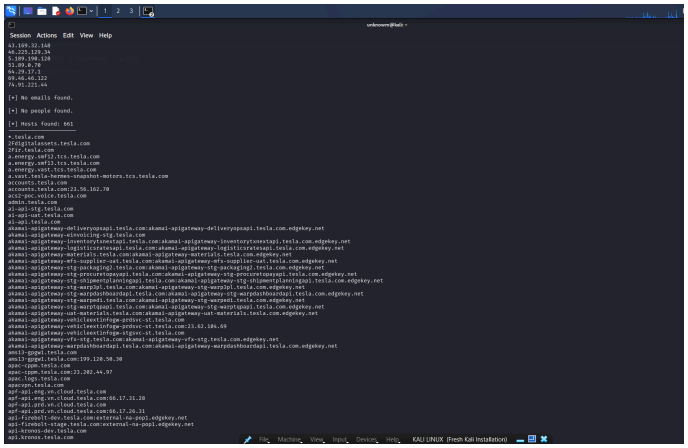

unknown@kali: ~
Session Actions Edit View Help
(unknown㉿kali)-[~]
$ theharvester -d tesla.com -b all -l 500
Read proxies.yaml from /etc/theHarvester/proxies.yaml
* theHarvester 4.11.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
[*] Target: tesla.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bevigil search for word: 'tesla.com'
Error Message:
[!] Missing API key for bevigil.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for Bitbucket.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bufferoverun search for word: 'tesla.com'
Error Message:
[!] Missing API key for bufferoverun.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to perform BuiltWith search for word: 'tesla.com'
A Missing Key Error occurred in builtwith:
[!] Missing API key for BuiltWith.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process brave search for word: 'tesla.com'
Error Message:
[!] Missing API key for Brave Search.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Censys API key is missing or invalid:
[!] Missing API key for Censys ID and/or Secret.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
A Missing key error occurred in criminalip:
[!] Missing API key for criminalip.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
A Missing Key error occurred in dehashed:
[!] Missing API key for Dehashed.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for DNSDumpster.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
A Missing key error occurred in dymo:
[!] Missing API key for dymo.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
A Missing Key error occurred in fullhunt:
[!] Missing API key for fullhunt.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Error initializing SearchGithubCode:
[!] Missing API key for Github.
File Machine View Input Devices Help
KALI LINUX (Fresh Kali Installation)

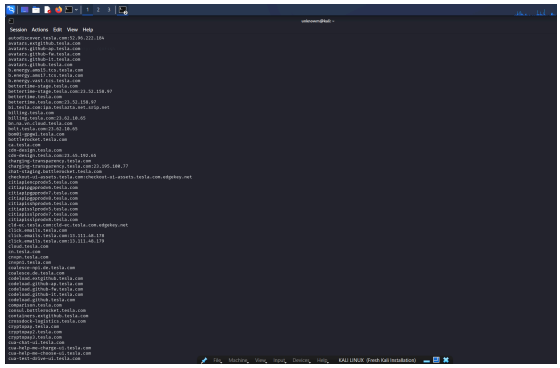


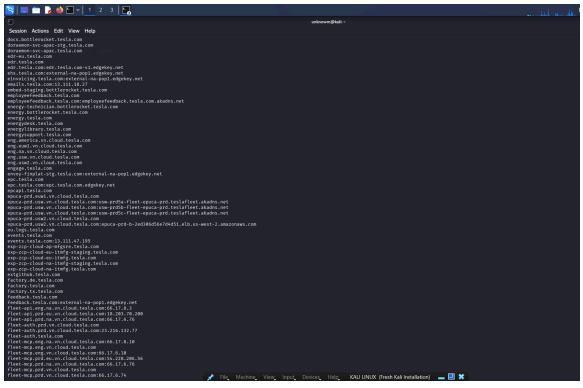


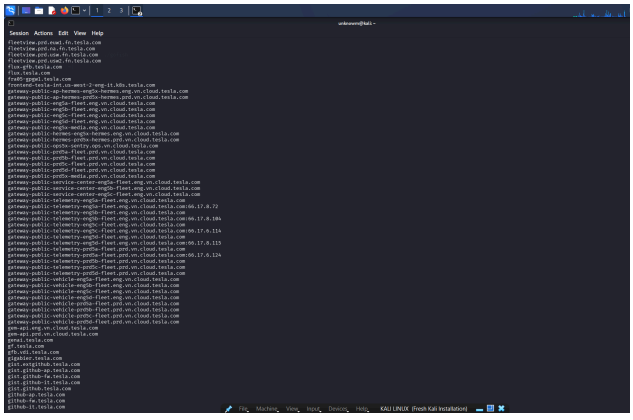


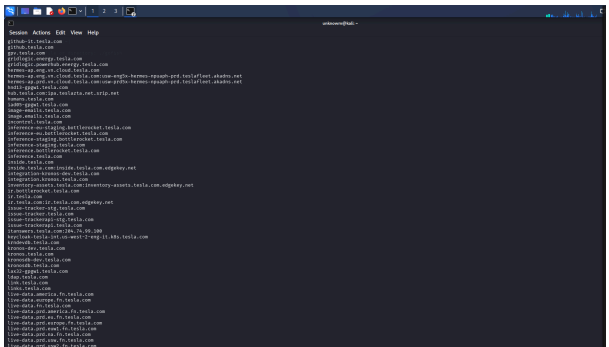


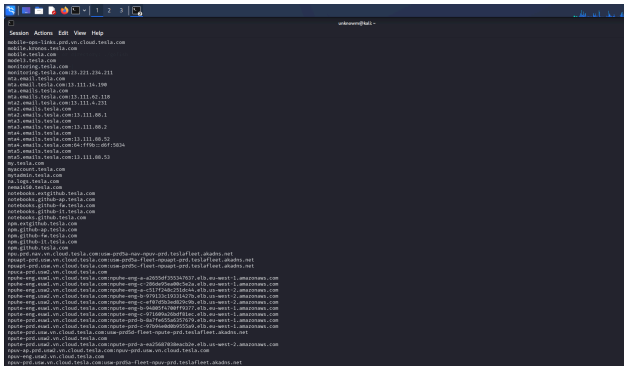


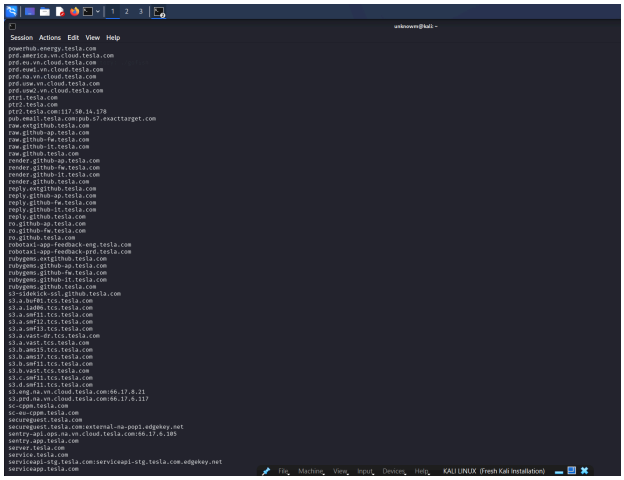


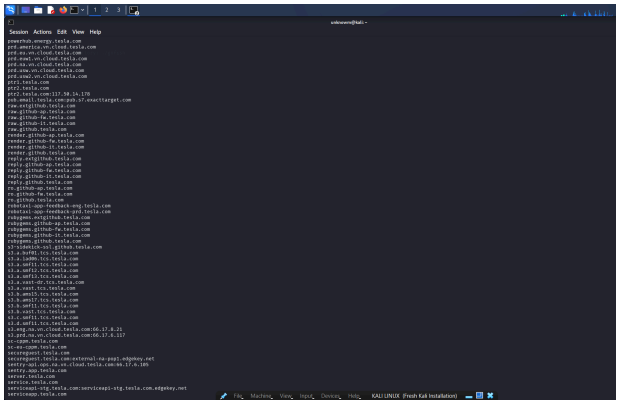


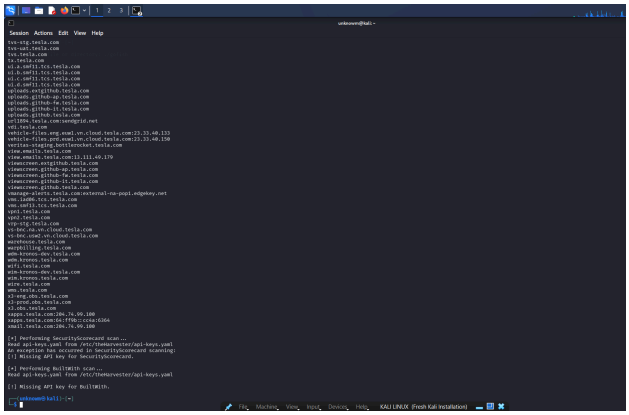












SECURITY ANALYSIS & FINDINGS

- **Email Categorization for Threat Modeling:**
    1. *Corporate Ingress / PR:* `press@tesla.com`, `ir@tesla.com` (useful for corporate impersonation or public relations spoofing).
    2. *Operational Support:* `energy_support@tesla.com`, `customercare@tesla.com` (frequently targeted with malicious ticket attachments).
    3. *Recruitment / HR:* `careers@tesla.com` (susceptible to resume droppers containing weaponized PDFs/macros).
    4. *Security / IT:* `security@tesla.com` (potential vector for urgent fake incident notifications).
- **Attack Surface Implications:**

    1. *Centralized Identity Gateways:* Discovery of `sso.tesla.com`, `mfa.tesla.com`, and `origin-sspr.tesla.com` reveals authentication infrastructure suitable for credential harvesting lures.
    2. *Internal Staging & API Hosts:* Exposure of subdomains like `dev-api.eng.vn.cloud.tesla.com` and `k8s.tesla.com` maps out internal naming conventions and development clusters.
    3. *Remote Access Points:* Identification of `vpn.tesla.com` reveals corporate perimeter gateways.
- **Defensive Recommendations:**
    1. Restrict public indexing of internal subdomains via DNS sanitization and certificate transparency monitor controls.
    2. Enforce phishing-resistant FIDO2 hardware MFA across all public SSO and self-service password reset (SSPR) endpoints.
    3. Deploy external email banner warnings (`[EXTERNAL]`) and enforce strict SPF, DKIM, and DMARC (`p=reject`) policies.
    4. Train department personnel to verify external attachments and suspicious communications through secondary channels.

RESULT

Passive reconnaissance and OSINT information gathering were executed against the target domain using **theHarvester** in Kali Linux. The process identified public email directories, corporate naming patterns, and external domain entry points without transmitting active network packets directly to target servers.